Deployment Plan—CliniFlow AI

Team Name : Dependency Free

Participant Name : Tang Shao Xian

1. Principles & SLO Targets **4**
SLO Contract 4
2. Production Architecture **5**
3. Deployment Strategy **6**
3.1 Grayscale rollout (mirrors SAD §4.1.1) 6
3.2 Strategy trade-off 6
3.3 Promotion path 6
4. CI/CD Pipeline **7**
4.1 Quality gates 7
4.2 Branch protection (target) 7
4.3 Platform — GitHub Actions chosen over GitLab CI / Jenkins (free for public repos, GHCR included, OIDC-tight integration). 7
5. Containerization & Orchestration **8**
5.1 Image strategy 8
5.2 Compose vs Kubernetes — trade-off 8
5.3 Image registry 8
6. Configuration & Secrets Management **8**
7. Database Migrations **9**
8. Monitoring & Observability **10**
8.1 Three-tier stack (all free-tier) 10
8.2 Four golden signals per service (latency, traffic, errors, saturation) 10
8.3 Planned dashboards 10
8.4 Logging & correlation 10
9. Alert Routing & Priority Matrix **11**
9.1 Concrete alert examples (Grafana / Prometheus rules) 11
9.2 On-call (pilot) 12
10. Emergency Action: Incident Response & Rollback **12**
10.1 Golden Release strategy 12
10.2 Rollback triggers 12
10.3 Graceful degradation paths 13
10.4 Incident response playbook (5 phases) 13
11. Resilience Patterns **14**
12. Backup, DR & Business Continuity **14**
13. Security & Credential Management **15**
13.1 Threat model — top 5 15
13.2 PDPA compliance 15
13.3 CI security automation 15
14. Capacity & Cost **16**
14.1 Scaling phases 16
14.2 Per-clinic monthly cost (pilot) 16
15. External Dependencies & Vendor Risk **17**

1. Principles & SLO Targets

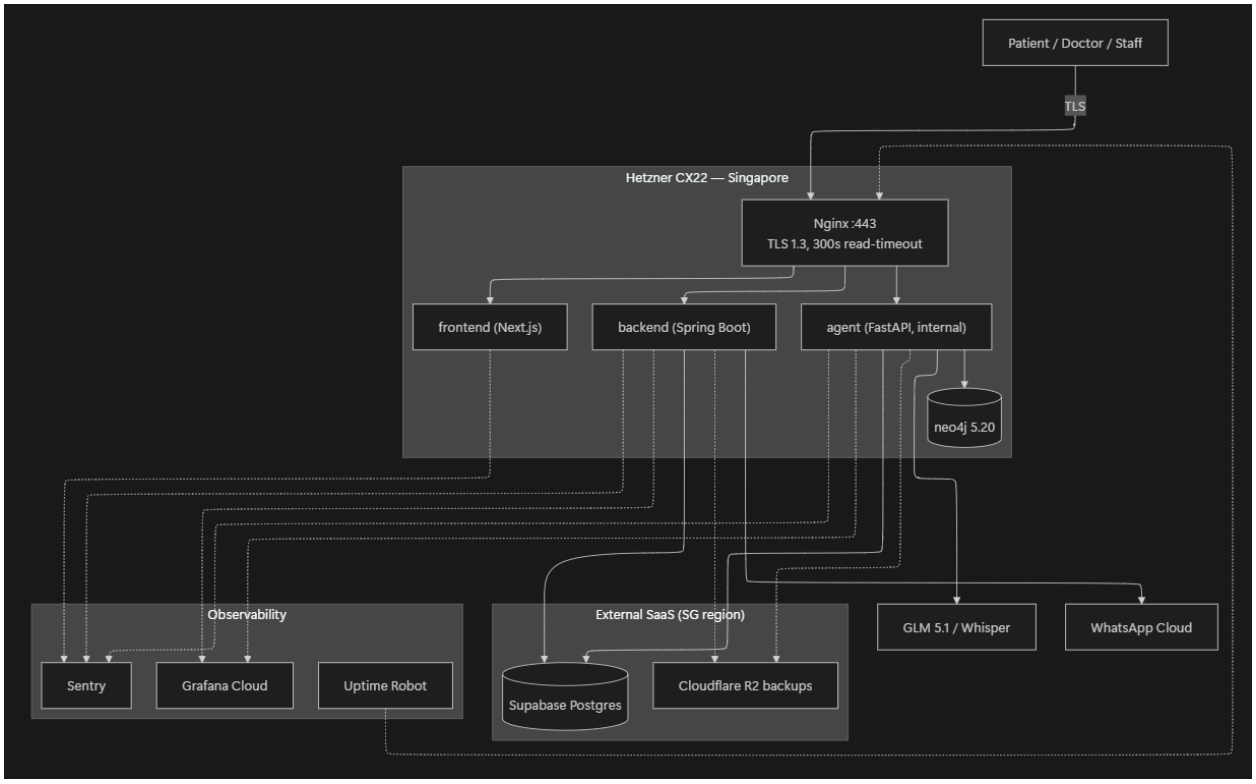
Five principles drive every decision, derived from the user persona (10-doctor SME clinic in Malaysia, **no in-house DevOps**) and clinical-software safety requirements.

1. **Safety first** — doctor-in-the-loop is non-negotiable; no rollout, flag, or A/B may bypass the finalize gate.
2. **Single-host first** — pilot on one VM. K8s deferred until 30+ clinics.
3. **Reversibility over speed** — every change reversible in < 5 min via Golden Release.
4. **Observe before optimize** — Sentry + Uptime Robot + Grafana Cloud live before any clinic onboards.
5. **SaaS-first, free-tier-friendly** — hosted SaaS replaces self-hosted unless PDPA blocks it.

SLO Contract

Metric	Pilot	Phase 2	Measured by
End-to-end uptime	99.5%	99.9%	Uptime Robot 5-min probe
p95 SOAP-generation latency	≤ 8 s	≤ 5 s	Micrometer histogram
RTO / RPO	30 min / 24 h	10 min / 1 h	Quarterly DR drill
Rollback time	≤ 5 min	≤ 2 min	Trigger → Golden live

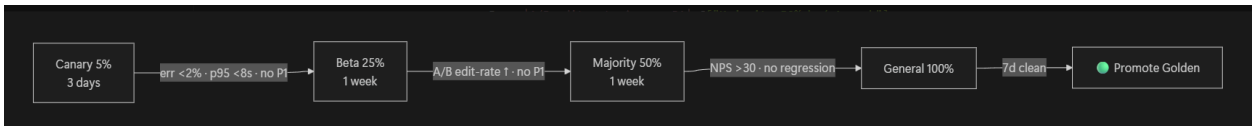
2. Production Architecture



- **Public surface**: only `:443` + `:22` (SSH key-only). All other ports blocked by UFW.
- **Data residency**: every store in `ap-southeast-1` (Singapore). No clinical data leaves ASEAN.
- **Inter-service auth**: shared `AGENT_SERVICE_TOKEN` today; **mTLS in Phase 1**.
- **TLS**: Let's Encrypt + certbot cron, ECDSA P-256, TLS 1.3 only, HSTS preload.

3. Deployment Strategy

3.1 Grayscale rollout (mirrors SAD §4.1.1)

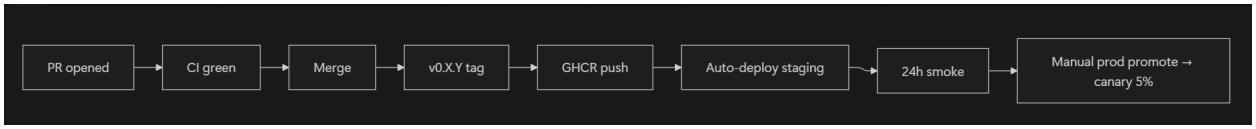


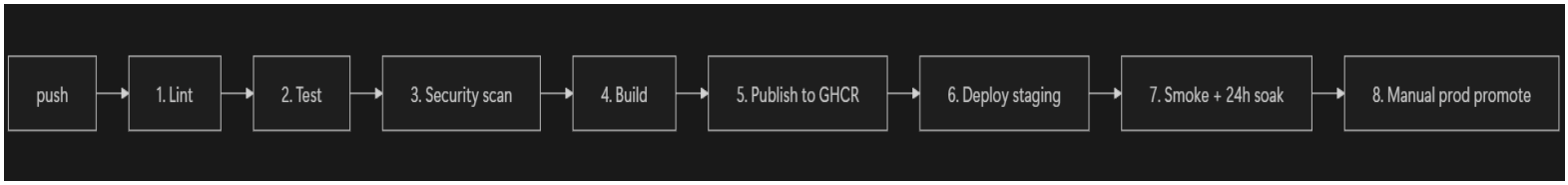
A/B during Beta: treatment = adaptive Hermes rules enabled; control = baseline prompts. Primary metric: doctor edit-rate. Target: ≥ 20% relative reduction over 2 weeks.

3.2 Strategy trade-off

Strategy	Decision	Why
Grayscale / canary	✅ Chosen	Quantitative gates; A/B compatible; cheap with Nginx upstream weights
Blue-green	⏳ Phase 2	Doubles infra cost; deferred until spare capacity exists
In-place rolling restart	❌ Rejected	Bad release hits 100% immediately — unsafe for clinical workloads
Feature flags (Flagsmith)	⏳ Phase 2	Self-host on same VM when per-clinic exposure becomes useful

3.3 Promotion path





4.1 Quality gates

Gate	Tool	Threshold	Status
Backend tests + coverage	JUnit 5 + Testcontainers + JaCoCo	100% pass · ≥ 50% line cov (target 70%)	✅ blocking
Frontend types + lint + build	tsc + ESLint + next build	0 errors · build succeeds	✅ blocking
Agent tests + lint	pytest + ruff	100% pass · 0 errors	✅ blocking
Secrets scan	gitleaks v2	0 findings (full history)	✅ blocking
Image / Dockerfile scan	aquasecurity/trivy	0 CRITICAL	warn → blocking Phase 1
Compose smoke build	docker compose build	must succeed	✅ blocking
Playwright E2E + dep audit	@playwright/test + npm audit + OWASP	critical paths pass	⏳ Phase 1

4.2 Branch protection (target)

PR review required · all checks pass · no force-push · squash-merge only · signed commits at Phase 2.

4.3 Platform — GitHub Actions chosen over GitLab CI / Jenkins (free for public repos, GHCR included, OIDC-tight integration).

---

5. Containerization & Orchestration

5.1 Image strategy

Multi-stage Docker images for all three services. Non-root user, HEALTHCHECK directive, pinned base-image SHAs at Phase 1.

Service	Runtime base	Target size
backend	`eclipse-temurin:21-jre-alpine`	~ 200 MB
agent	`python:3.12-slim`	~ 300 MB
frontend	`node:20-alpine` (standalone)	~ 150 MB

5.2 Compose vs Kubernetes — trade-off

Phase	Choice	Trigger
0–1 (1–5 clinics)	✅ Docker Compose on single VM	Operationally simple, matches solo-dev skill
2–3 (5–30 clinics)	⏳ k3s	Multi-node + declarative becomes worth the ops cost
4 (30+ clinics)	⏳ Managed K8s	Per-region clusters; multi-tenant isolation

5.3 Image registry

GHCR with three tag classes: `sha-<7-char>` (90-day retention), `v0.X.Y` (forever), `golden-YYYYMMDD` (forever).

---

6. Configuration & Secrets Management

Phase	Approach
Today	`.env` files per env (git-ignored); `.env.example` committed; agent fail-fasts on placeholder secrets
Phase 1	Docker Compose **`secrets:`** mounts (file-based, removes from `docker inspect`)
Phase 2	**Infisical** (free tier, UI, per-env scopes) — Vault deferred due to ops burden

CI guards: gitleaks (full history, blocking), detect-secrets pre-commit (Phase 1), `.gitignore` for `.env*` / `*.pem` / `*.key` / `*.bak*`.

Rotation cadence: 90 days for API keys; 180 days for DB passwords; immediate on personnel change or suspected leak.

---

7. Database Migrations

Process: author `V<N>__<desc>.sql` → review in PR → operator applies via Supabase SQL editor → deploy app image *after* migration succeeds. JPA runs `ddl-auto: none`.

Compatibility: HikariCP `prepareThreshold=0`; asyncpg `statement_cache_size=0`.

Neo4j: idempotent constraints (`IF NOT EXISTS`) at FastAPI lifespan startup.

Append-only invariants: `audit_log` and `agent_turns` have BEFORE UPDATE / BEFORE DELETE triggers raising `EXCEPTION`. **Never UPDATE or DELETE from app code.**

---

8. Monitoring & Observability

8.1 Three-tier stack (all free-tier)

Tool	Purpose	Free-tier limit
Sentry	Error tracking, stack traces, release tagging	5 k events / mo
Uptime Robot	External HTTP probes (5-min interval, multi-region)	50 monitors
Grafana Cloud	Prometheus metrics + Loki logs + Tempo traces + dashboards	10 k series / 50 GB logs

Self-hosted fallback: Prometheus + Grafana + Loki on same VM via Docker Compose, only if PDPA review requires telemetry to remain on-premise.

8.2 Four golden signals per service (latency, traffic, errors, saturation)

Spring Boot via Micrometer + Actuator (`/actuator/prometheus`). Python agent via `prometheus_client` (`/metrics`).

8.3 Planned dashboards

1. **System Health** — uptime, errors, latency. First dashboard on-call opens.
2. **AI Pipeline** — GLM latency, token usage, cost per consultation, STT confidence.
3. **Clinical Quality** — adaptive-rule acceptance, edit-rate trend, drug warnings surfaced.
4. **Data Layer** — Postgres query latency by table, Neo4j multi-hop drug query, graph size.

8.4 Logging & correlation

Structured JSON to stdout → Loki. **`X-Correlation-ID`** generated at gateway, propagated to agent. One-line cross-service trace: `{correlation_id="abc123"}`. **No PHI in app logs** — phone numbers SHA-256 hashed; Sentry `sendDefaultPii: false`. Audit log is a separate Postgres table with append-only triggers.

9. Alert Routing & Priority Matrix

Combines **SAD §4.1.3 + §4.2.4**.

Priority	Trigger	SLA	Action	Channel
P0	PHI leak / unauthorized access / data corruption	Immediate	Full freeze; forensic snapshot via `audit_log`; legal notify	Phone + war room
P1	GLM error rate > 5% / 5 min OR clinically dangerous content	< 15 min	Auto-rollback to Golden; disable AI agents	PagerDuty / phone
P2	Edit rate > 30% OR p95 latency > 10 s	< 1 h	Switch to cached/simplified prompts	Slack @here
P3	Adaptive-rule rejection > 50% / 24 h	< 24 h	Pause adaptive learning	Slack + daily digest
P4	Minor UI / non-critical feature	Next sprint	Backlog	GitHub issue

9.1 Concrete alert examples (Grafana / Prometheus rules)

```yaml
- alert: GLMHighErrorRate              # P1 — auto-rollback
  expr: rate(glm_errors_total[5m]) / rate(glm_requests_total[5m]) > 0.05
  for: 5m
  labels: { severity: P1 }

- alert: VisitAgentLatencyHigh         # P2
  expr: histogram_quantile(0.95, rate(http_request_duration_seconds_bucket{service="visi
  for: 10m
  labels: { severity: P2 }

- alert: AdaptiveRuleRejectionTrend    # P3
  expr: avg_over_time(rule_acceptance_rate[24h]) < 0.5
  for: 1h
  labels: { severity: P3 }
```

9.2 On-call (pilot)

Solo developer 24/7: 09:00–21:00 KL active (< 5 min ack); 21:00–09:00 phone wakeup for P0/P1 only.

Phase 2 → secondary engineer + PagerDuty rotation.

---

10. Emergency Action: Incident Response & Rollback

10.1 Golden Release strategy

`cliniflow-<svc>:golden-YYYYMMDD` is the most-recent stable image. Promotion only after 7 days at General-stage with no P1 incident. Always available as the rollback target.

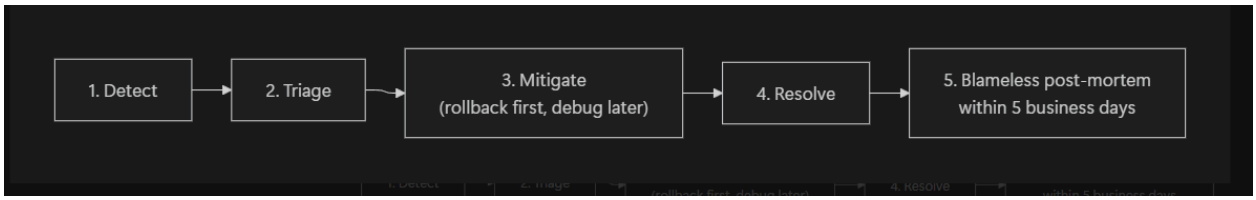
10.2 Rollback triggers

Trigger	Mechanism	Recovery
Automated (P1 alert fires)	Grafana → webhook → GitHub Actions `workflow_dispatch` redeploys Golden	< 5 min
Manual (subjective issue)	On-call triggers `workflow_dispatch` with rollback flag	< 10 min
Schema rollback	Reverse-migration via Supabase SQL editor + image rollback	< 30 min
Full restore (VM loss)	Provision new CX22 + restore latest `pg_dump`	< 30 min (RTO)

10.3 Graceful degradation paths

Component down	Behavior	User-visible
GLM (LLM)	Visit module → manual SOAP entry; CRUD continues	"AI assist unavailable" banner
Whisper (STT)	Doctor types transcript	"Voice transcription unavailable"
Neo4j	Postgres-only context; no drug-interaction warnings	Evaluator panel notice
Postgres	Backend returns 503 — fail closed	"Service temporarily unavailable"

10.4 Incident response playbook (5 phases)



P0 war-room: on-call calls clinic contact within 5 min · open conference bridge · **freeze deploys** · forensic snapshot via `audit_log` query · notify legal if PHI involved · stand down only after 4 h verified clean.

Post-mortem template: TL;DR · timeline · impact · 5-whys root cause · what went well/poorly · owned + dated action items. Stored in `docs/post-mortem/`.

---

11. Resilience Patterns

Spring Boot — Resilience4j:

- *Circuit breaker* on `llm`, `stt` — 50% failure threshold, 30 s open, 20-call window.
- *Time limiter* — `llm` 300 s, `stt` 30 s. Exceeded → degraded fallback, not error.
- *Rate limiter* — per-doctor LLM call rate (Phase 1).

Python agent — tenacity + httpx: exponential backoff with jitter on 5xx/429, strict per-call timeout, in-memory rate limiter, boot-time fail-fast on placeholder secrets, non-fatal Neo4j probe.

Outbox pattern (WhatsApp): messages written to `notification_outbox` in same DB transaction as business event; drainer polls every 30 s; max 5 retries with backoff; idempotency-key safe.

---

12. Backup, DR & Business Continuity

Store	Method	Frequency	Retention
Supabase Postgres	`pg_dump` • Supabase PITR	Daily 02:00 KL + 7-day PITR	30d / 12mo / 7yr
`audit_log` (PDPA)	WAL streaming replica	Continuous (RPO ≤ 1 h)	≥ 7 yr
Neo4j	`neo4j-admin database backup`	Daily 02:30 KL	14 d
VM volume	Hetzner snapshot	Weekly	4 wk

Verification: monthly restore drill to disposable VM · quarterly RTO drill against SLO · `last_successful_backup_at` Prometheus gauge alerts P3 if > 28 h stale.

BCP scenarios: VPS region outage → reprovision in alt Hetzner region from R2 backup. LLM extended outage → manual-entry SOAP path (always functional). Solo-dev unavailable → runbooks (this doc) sufficient for contracted DevOps engineer.

---

13. Security & Credential Management

13.1 Threat model — top 5

Threat	Control
Cross-patient PHI leak	Server-derived identity from JWT principal; ownership check on path-param IDs
Secret leak in repo	gitleaks in CI on full history; rotation procedure
Broken authorization	Spring Security `@PreAuthorize` defaults; security-reviewer on `controller/` PRs
SQL / Cypher injection	JPA + parameterized queries; no string interpolation in Cypher
LLM prompt injection	Doctor-in-the-loop non-negotiable; 3-point evaluator soft-block; Hermes scoped to style only

13.2 PDPA compliance

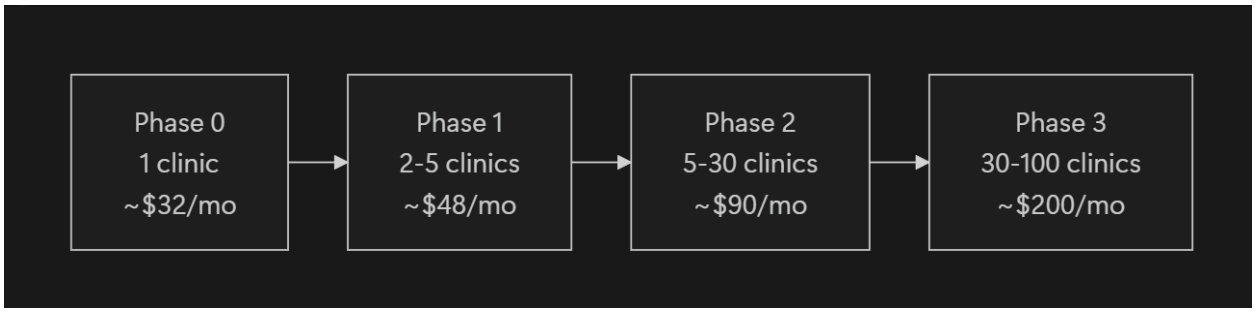
- Append-only audit log (DB triggers reject UPDATE/DELETE).
- Every CRUD on patient data writes audit row (verified by integration tests).
- WhatsApp opt-in with version-stamped consent text.
- Data subject rights — patient can export own record (PDF).
- Data residency — SG region only.
- Retention — clinical ≥ 6 yr (Malaysian Medical Act); audit log ≥ 7 yr.

13.3 CI security automation

Tool	Scope	Status
gitleaks v2	Full git history	✅ blocking
Trivy	Dockerfile + image CVE	warn → blocking Phase 1
npm audit + OWASP dep-check	Dep CVEs	⏳ Phase 1
Dependabot	Auto-PR weekly	⏳ Phase 1

14. Capacity & Cost

14.1 Scaling phases



Per-layer levers: FE → Cloudflare CDN; BE → HikariCP pool + virtual threads → horizontal scale; Agent → uvicorn workers → dedicated VM + queue; Postgres → indexes + read replica; Neo4j → cache pre-warm + replicas.

Load testing: k6 baseline (10 doctors × 30 visits) before each release; 3× spike test; 24 h soak on staging; monthly chaos kill.

14.2 Per-clinic monthly cost (pilot)

Item	Tier	USD/mo
Hetzner CX22 (2vCPU/4GB)	Paid	$5.50
Supabase + Neo4j + Sentry + Uptime Robot + Grafana Cloud	All free-tier	$0
GLM 5.1 (LLM)	Pay-per-toke n	~$15
Whisper (STT) + Cloudflare R2 + Domain + WhatsApp	Pay-per-use	~$11.50
Total		**~ USD 32 (RM 150)**

Cost per consultation: ~ USD 0.048 all-in @ 660 visits/mo. 95% gross margin at RM 5/consultation.

Free-tier exhaustion: Sentry @ ~50 errors/day; Supabase Free @ ~5 clinics; Grafana series @ ~5 clinics; Uptime Robot @ ~12 clinics. Phase-1 paid budget USD 50/mo.

---

15. External Dependencies & Vendor Risk

Vendor	Criticality	Mitigation
Z.AI GLM (via ILMU)	**High**	OpenAI-compatible interface → swap to gpt-4o-mini in <1 day; manual SOAP path always available
Supabase Postgres	**High**	Daily `pg_dump` to R2; restorable to any Postgres host
OpenAI Whisper	Medium	Doctor falls back to text input; STT abstracted internally
Hetzner	Medium	Multi-region snapshots; reprovisionable in any region
WhatsApp (Meta / Twilio)	Low	Outbox decouples send; pluggable via `WHATSAPP_PROVIDER` env
Sentry / Uptime Robot / Grafana Cloud	Low	SDKs no-op when DSN unset; self-hosted fallback documented

---

16. Roadmap

Sprint 1 — Pre-pilot (next 14 days): CD workflow on tag · Codecov badge · Grafana Cloud dashboard · ADR log · `SECURITY.md` + templates · DR drill #1.

Sprint 2 — Pilot launch (days 15–42): Pilot clinic #1 LOI · per-clinic VM bootstrap · doctor/staff training · 7-day shadow deploy · live cutover · 14-day soak.

Sprint 3 — Hardening (days 43–90): secrets → Compose `secrets:` mounts · mTLS backend↔agent · read-replica · Loki · Trivy blocking · Dependabot · pilot clinic #2.

Phase 2+ (months 4–12): k3s @ 5+ clinics · Infisical · Flagsmith · mutation testing · multi-tenant RLS · Bahasa Melayu STT.